

Exercício 11 — Análise de Tendências de Vulnerabilidades

Objetivo: Aprender a analisar tendências em vulnerabilidades ao longo do tempo usando o NVD.

Pesquise vulnerabilidades relacionadas ao kernel Linux no NVD. Aplique filtros para o ano atual. Analise por trimestre (Q1: janeiro a março, Q2: abril a junho) e escreva um relatório resumindo os resultados.

11. Análise de Tendências de Vulnerabilidades — Kernel Linux (2026)

Metodologia de Pesquisa

Fonte: NVD — Banco de Dados Nacional de Vulnerabilidades (nvd.nist.gov)

Parâmetros de pesquisa utilizados: - Palavra-chave: `linux kernel` - Período: 1º de janeiro de 2026 → 18 de junho de 2026 - Filtros: data de publicação, separado por trimestre

Contexto Histórico — Contagem Anual de CVEs no Kernel Linux

Ano	Total de CVEs	Variação
2019	594	—
2020	693	+17%
2021	812	+17%
2022	1.064	+31%
2023	1.736	+63%

Ano	Total de CVEs	Variação
2024	3.108	+79%
2025	~5.530	+78%

O kernel Linux se tornou o **componente de software mais reportado no NVD** — não porque o Linux ficou menos seguro, mas porque o kernel cresceu massivamente em complexidade e o ecossistema de reportagem amadureceu significativamente.

Análise Trimestral 2026

Q1 — Janeiro a Março de 2026

Métrica	Dado
CVEs publicados (estimado)	~1.300–1.400
Média por mês	~430–470
Média por dia	~14–15
Severidade dominante	Médio (49%) / Alto (42%)

Tendência: Continuou no ritmo estabelecido no final de 2025. Nenhum zero-day de amplo impacto afetou o Q1, mas um fluxo constante de vulnerabilidades em subsistemas (drivers USB, pilha de rede, sistemas de arquivos) sustentou o alto volume.

Q2 — Abril a Junho de 2026 (parcial — até 18 de junho)

Métrica	Dado
CVEs apenas em abril	~248 (Linux liderou todos os fornecedores)

Métrica	Dado
Total Q2 estimado	~700-800
CVEs notáveis	CVE-2026-31431, CVE-2026-46333

Tendência: O Q2 trouxe duas vulnerabilidades de alto perfil que chamaram atenção significativa:

CVE-2026-31431 — "Copy Fail" (29 de abril de 2026)

- **Severidade:** Alto
- **Tipo:** Escalada Local de Privilégios
- **Impacto:** Permitia que usuários locais escalassem para root por meio de uma falha de cópia de memória

CVE-2026-46333 (maio de 2026)

- **Severidade:** Alto
- **Tipo:** Escalada Local de Privilégios via caminho ptrace
- **Impacto:** Usuário local sem privilégios podia ler arquivos sensíveis e executar comandos como root em distribuições Linux principais (Debian, Ubuntu, Red Hat)

Distribuição de Severidade (2026)

Severidade	CVSS	Aprox. %	Significado
Crítico	9,0-10,0	~5%	Raro, mas devastador
Alto	7,0-8,9	~42%	Maior grupo explorável
Médio	4,0-6,9	~49%	Requer mais condições para explorar
Baixo	0,1-3,9	~4%	Risco prático mínimo

Padrões e Conclusões

Padrão 1 — Volume continua crescendo

Os CVEs do kernel Linux cresceram mais de 1.100% entre 2019 e 2024. O ritmo não diminuiu em 2025–2026. As equipes de segurança agora enfrentam **uma média de 14-15 novos CVEs de kernel por dia**.

Padrão 2 — Escalada de privilégios domina

Os dois CVEs notáveis do Q2 de 2026 são vulnerabilidades de **escalada local de privilégios**. Este é um padrão consistente — o limite do kernel entre o espaço do usuário e o espaço do kernel é onde a maioria das falhas críticas aparece.

Padrão 3 — A maioria são Médios, mas os Altos geram o risco

Quase metade de todos os CVEs são de severidade Média. Porém, os 42% que são Alto — combinados com os 5% Críticos — representam a carga operacional real para as equipes de patches.

Padrão 4 — Subsistemas são a principal fonte

A maioria dos CVEs não está no núcleo do kernel, mas em **drivers e subsistemas** (USB, Bluetooth, rede, sistemas de arquivos). Isso significa que os patches são frequentes, mas geralmente com escopo limitado.

Recomendações com Base na Análise

1. **Assine listas de discussão de segurança do kernel** — os patches frequentemente chegam antes que o NVD publique o CVE.
 2. **Priorize CVEs Alto e Crítico com vetores de acesso local** — estes são os mais explorados em cenários pós-comprometimento.
 3. **Use gerenciamento automatizado de patches** — com 14+ CVEs por dia, o rastreamento manual não é viável.
 4. **Monitore o CISA KEV** — nem todos os CVEs de alta severidade são ativamente explorados; a CISA sinaliza os que são.
-

Resumo

*O volume de vulnerabilidades do kernel Linux cresceu exponencialmente desde 2019 e não dá sinais de desaceleração em 2026. Q1 e Q2 contribuem cada um com centenas de CVEs, sendo a escalada de privilégios o tipo de ameaça dominante. O desafio para as organizações não é encontrar os CVEs — o NVD os fornece — mas **triá-los e corrigi-los em escala** antes que os invasores possam explorá-los.*